

ARIA · SECURITY REVIEW

Aria

Updates Review.

A security review of Updates Review.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Aria	Updates Review	Guardian	September 17 – October 1, 2025	October 8, 2025

§ 00

Contents.

17 pages — overview, confidence ranking, scope, 7 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 4 findings	P. 08
	Remediation Review · 3 findings	P. 12
§ 05	Disclaimer	P. 16
§ 06	About Guardian	P. 17

§ 01

Overview.

Guardian reviewed Updates Review across 2 review rounds. The final report includes 1 High, 3 Medium, 1 Low, 2 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	AriaProtocol/main-contracts
CLIENT	METHODOLOGY
Aria	Smart contract · Manual · Main Review · Remediation Review
PROJECT	
Updates Review	
PREPARED BY	
Guardian	
AUDIT WINDOW	
September 17 – October 1, 2025	
FINAL REPORT	
October 8, 2025	

1.1 Confidence Ranking

4 / 5

High Confidence

Guardian assigns a Confidence Ranking of 4 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	1	0	0	0	1
Medium	3	0	0	0	3
Low	1	0	0	0	1
Informational	2	0	0	0	2
All severities	7	0	0	0	7

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence ASSIGNED	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Updates Review in `AriaProtocol/main-contracts`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
H-01	Rewards Included In "Total Staked"	Rewards	HIGH	RESOLVED	p. 8
M-01	Distribution Order In Unstake	Rewards	MEDIUM	RESOLVED	p. 9
M-02	Randomized Distribution Via Probability	Rewards	MEDIUM	RESOLVED	p. 10
L-01	Missing Parent Initializers	—	LOW	RESOLVED	p. 11
REMEDIATION REVIEW					
M-01	Incorrect Consideration of avgAPR	Logical Error	MEDIUM	RESOLVED	p. 12
I-01	Direct Donations to Staking Contract	Warning	INFORMATIONAL	RESOLVED	p. 14
I-02	Missing Admin Functions in IRoyaltiesHookAdmin	Best Practices	INFORMATIONAL	RESOLVED	p. 15

HIGH **H-01**

RESOLVED

Rewards Included In "Total Staked"

CATEGORY	Rewards
LOCATION	https://github.com/GuardianOrg/main-contracts-team1-1757976222228/blob/c7066a9598fa631b80fc0483adbc26336a91e1e5/contracts/iprwa/staking/hook/RoyaltiesHook.sol#L232
REVIEW	Main Review

— DESCRIPTION

The contract currently calculates total staked based on the contract's IPRWA balance. When royalties are deposited, they inflate the staking balance, effectively treating rewards as staked funds. This causes overestimation of staking size and dilution of later rewards.

— RECOMMENDATION

Maintain a dedicated `totalStaked` state variable updated only during stake/unstake actions.

— RESOLUTION

Status: Resolved.

<https://github.com/AriaProtocol/main-contracts/pull/131>

MEDIUM **M-01**

RESOLVED

Distribution Order In Unstake

CATEGORY	Rewards
LOCATION	https://github.com/GuardianOrg/main-contracts-team1-1757976222228/blob/c7066a9598fa631b80fc0483adbc26336a91e1e5/contracts/iprwa/staking/IPRWAStaking.sol#L177
REVIEW	Main Review

DESCRIPTION

In the current design, the `distribute` function is called after the unstake action. This means users receive IPRWA based on the previous snapshot, potentially under-allocating yield since they were contributing until the point of unstake. While this was intended to avoid gaming the system, it still leaves gaps: for example, a user can repeatedly stake as little as 1 wei to trigger distribution first and then immediately unstake, gaining advantage from timing.

RECOMMENDATION

Update distributions before calculating shares-to-assets conversion in the unstake function. This ensures users are attributed yield for the full duration of their stake and avoids unnecessary edge cases where minimal stakes can influence the distribution order.

RESOLUTION

Status: Resolved.

<https://github.com/AriaProtocol/main-contracts/pull/128>

MEDIUM **M-02**

RESOLVED

Randomized Distribution Via Probability

CATEGORY Rewards

LOCATION <https://github.com/GuardianOrg/main-contracts-team1-1757976222228/blob/c7066a9598fa631b80fc0483adbc26336a91e1e5/contracts/iprwa/staking/hook/RoyaltiesHook.sol#L71>

REVIEW Main Review

DESCRIPTION

The protocol introduces randomness (interval + delta) to determine whether distributions occur. While the intent is to mitigate MEV at boundaries, this randomness can be bypassed by wrapper contracts that deterministically call stake only when distribution would be skipped.

Randomness could also result in one set of users not getting attributed to their yield, while one set is.

It also requires consideration of `forceDistribute` by admin.

Hence, the probabilistic design increases complexity without clear security gains.

RECOMMENDATION

Consider streaming royalties proportionally based on elapsed time since the last distribution. For example, distribute $(\text{elapsed} / \text{year}) * \text{yearlyDistribution}$. This approach:

- Eliminates exploitable randomness,
- Reduces unnecessary complexity,
- Ensures smooth, continuous distribution,
- Aligns directly with stake/unstake actions already in place.

RESOLUTION

Status: Resolved.

<https://github.com/AriaProtocol/main-contracts/pull/130>

LOW **L-01**

RESOLVED

Missing Parent Initializers

CATEGORY —

LOCATION <https://github.com/GuardianOrg/main-contracts-team1-1757976222228/blob/c7066a9598fa631b80fc0483adbc26336a91e1e5/contracts/iprwa/staking/hook/RoyaltiesHook.sol#L53-L54>

REVIEW Main Review

DESCRIPTION

The `initialize()` function of `RoyaltiesHook` only calls `__ReentrancyGuard_init()`, but does not invoke `__AccessControl_init()` or `__UUPSUpgradeable_init()`.

Currently, these functions are empty in the OpenZeppelin 0.8.x implementation, so the contract will work as expected. However, skipping them breaks the standard upgradeable-contract initialization pattern and may cause problems if OpenZeppelin adds initialization logic in future versions or if multiple inheritance chains rely on proper linearization.

RECOMMENDATION

Call all inherited initializer functions inside `initialize()` to preserve upgrade-safe patterns and maintain forward compatibility:

```
__AccessControl_init();
__ReentrancyGuard_init();
__UUPSUpgradeable_init();
```

RESOLUTION

Status: Resolved.

<https://github.com/AriaProtocol/main-contracts/pull/129>

MEDIUM **M-01**

RESOLVED

Incorrect Consideration of avgAPR

CATEGORY	Logical Error
LOCATION	https://github.com/AriaProtocol/main-contracts/blob/30fdd642f2a618ef138a44c276d3f36ab2fe9165/contracts/iprwa/staking/hook/RoyaltiesHook.sol#L164-L165
REVIEW	Remediation Review

DESCRIPTION

The current comment suggests that `avgAPR` is used to calculate the total amount of royalties to be distributed.

`avgAPR` is used to calculate the total amount of royalties to be distributed, whereas

This is incorrect.

- `APR` represents the intended annual reward rate (e.g., 10%).
- `avgAPR` represents how much has already been rewarded (but not yet claimed), relative to the staked balance.

For example:

- Initial stake = 1000 tokens, APR = 10%.
- Expected yearly rewards = 100 tokens.
- After one month: $100 \div 12 = 8.33$ tokens accrued.
- `avgAPR` at this point = $(8.33 \div 1000) \times 100\% \approx 0.833\%$.

If a user claims rewards, `avgAPR` must decrease accordingly. Therefore, `avgAPR` must always be adjusted as:

`avgAPR = (rewards accrued - claimed) / stake × 100%`

RECOMMENDATION

Calculate `avgAPR` considering above and ensure that `avgAPR` is consistently adjusted after claims, so it accurately reflects outstanding (unclaimed) rewards.

Also consider correcting comment in contract to reflect actual nature of `avgAPR`.

RESOLUTION

Status: Resolved.

M-01 Incorrect Consideration of avgAPR

CONTINUED

<https://github.com/AriaProtocol/main-contracts/pull/136>

INFORMATIONAL I-01

RESOLVED

Direct Donations to Staking Contract

CATEGORY	Warning
LOCATION	Global
REVIEW	Remediation Review

DESCRIPTION

Direct donations increase `stakedAndRewards` but not `approxRewards`. While normally unattractive (since donors effectively give value to others), this creates a potential exploit during the vault's initial phase.

Attack Scenario

1. A malicious actor deposits 1 wei as the first stake.
2. They wait for time to pass.
3. Instead of staking again (which updates `lastDistributionTime`), they donate directly.
4. The system incorrectly treats this donation as if it had been staked since the beginning, releasing more rewards than intended.

If the first few depositors collude, they could inflate rewards early on at minimal cost.

RECOMMENDATION

On redeployment or when vault doesn't have much deposits, consider making the first substantial deposit to prevent exploitation by early depositors.

RESOLUTION

Status: Resolved.

<https://github.com/AriaProtocol/main-contracts/pull/136>

INFORMATIONAL I-02

RESOLVED

Missing Admin Functions in IRoyaltiesHookAdmin

CATEGORY Best Practices

LOCATION <https://github.com/AriaProtocol/main-contracts/blob/30fdd642f2a618ef138a44c276d3f36ab2fe9165/contracts/iprwa/staking/hook/interfaces/IRoyaltiesHookAdmin.sol#L3-L4>

REVIEW Remediation Review

DESCRIPTION

The `IRoyaltiesHookAdmin` interface currently lacks functions for updating key parameters:

- `APR` (the target annual reward rate)
- `avgAPR` (the effective reward rate already accrued but not yet claimed)

RECOMMENDATION

Consider extending `IRoyaltiesHookAdmin` to include:

- `setAPR(uint256 newAPR)`
- `setAvgAPR(uint256 newAvgAPR)`

RESOLUTION

Status: Resolved.

<https://github.com/AriaProtocol/main-contracts/pull/137>

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.